Inventory and Asset Monitoring (NESSUS)

CYBERSECURITY

MAHBOUBA REZAEI - REZ23579670
UNIVERSITY OF ROEHAMPTON
30 MARCH 2026

GITHUB LINK: GITHUB LINK: https://github.com/M12rezaei/CyberSecurity.git

Contents

What is Nessus? 2
How Nessus Works 2
Capabilities and Uses 2
Network Vulnerability Assessment using Nessus 3
Introduction 3
Methodology 3
Environment Setup 3
Target Configuration 4
Scan Results Summary 5
Detailed Finding and Remediation 6
Conclusion 6
Reference 8

What is Nessus?

Nessus is a vulnerability assessment tool designed to automate the testing and discovery of known security problems. Originally released as a public domain program under the GPL, it is used by security analysts and system administrators to assess the security posture of servers and workstations on a network [1].

The tool operates using a client-server architecture:

- Nessus Server: Performs the actual testing and runs on various flavours of Unix, including Linux, MACOS, and IBM/AIX [1].
- Nessus Client: Provides configuration and reporting functionality. Clients are available for both Windows and Unix [1].

How Nessus Works

Nessus identifies security issues through the following process:

- Probing: It probes machines to determine open network ports and identify running services and their specific versions [2].
- Matching: It matches the identified service versions against a database of known vulnerabilities [2].
- Plug-ins: The tool uses “plug-ins”, which are similar to virus signatures. Each plug-in is a script (often written in Nessus Attack Scripting Language or NASL) designed to test for a specific vulnerability or industry best practice [1].
- Port Scanning: It utilises port scanners, such as a built-in internal scanner or a wrapper for Nmap, to identify active ports and the programs tied to them [1].

Capabilities and Uses

According to the research papers, Nessus can be used for:

- Identifying Vulnerabilities: It can detect both local and remote vulnerabilities by checking for known bugs in software [1].
- Configuration and Compliance: It can test for industry best practices and identify port-to-program mappings [1].
- Comparison and Tracking: Advanced visualisation tools (like nv) allow analysts to compare sequential scans to see which vulnerabilities have been fixed, which remain open, and which are newly discovered [1].
- Criticality Management: Analysts can specify logical groupings of machines and manage criticality scores to ensure high value assets receive priority attention [2].
- Custom Testing: Users can write their own custom plug-ins in NASL for special purpose testing [1].

Network Vulnerability Assessment using Nessus

Introduction

The objective of this lab was to deploy Tenable Nessus on a Kali Linux virtual machine to perform a vulnerability assessment. The goal was to identify security weaknesses in two distinct targets, a standard web server (WordPress) and a deliberately insecure web application (Juice Shop)

Methodology

Environment Setup

The installation was performed on a Kali Linux environment. The system was first updated using 'sudo apt update && apt upgrade' to ensure all dependencies were current.

Installation: The Nessus package (Nessus-10.11.3-ubuntu1604_amd64.deb) was installed using Debian package manager:

'sudo dpkg -I Nessus-10.11.3-ubuntu1604_amd64.deb'

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo dpkg -i Nessus-10.11.3-ubuntu1604_amd64.deb
Selecting previously unselected package nessus.
(Reading database… 465892 files and directories currently installed.)
Preparing to unpack Nessus-10.11.3-ubuntu1604_amd64.deb…
Unpacking nessus (10.11.3)…
Setting up nessus (10.11.3)…
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

 - You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
 - Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner
```

Figure 1. Executing the Nessus installation on Kali Linux using the dpkg command

Service Start: After installation, the Nessus daemon was initialised with:

‘sudo /bin/systemctl start nessusd.service’

```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo /bin/systemctl start nessusd.service
```

Figure 2. Initial Connection to the Nessus Web Interface at https://localhost:8834

Web interface: Access was gained via

‘https://localhost:8834/. A self-signed certificate warning was bypassed to reach the configuration wizard.

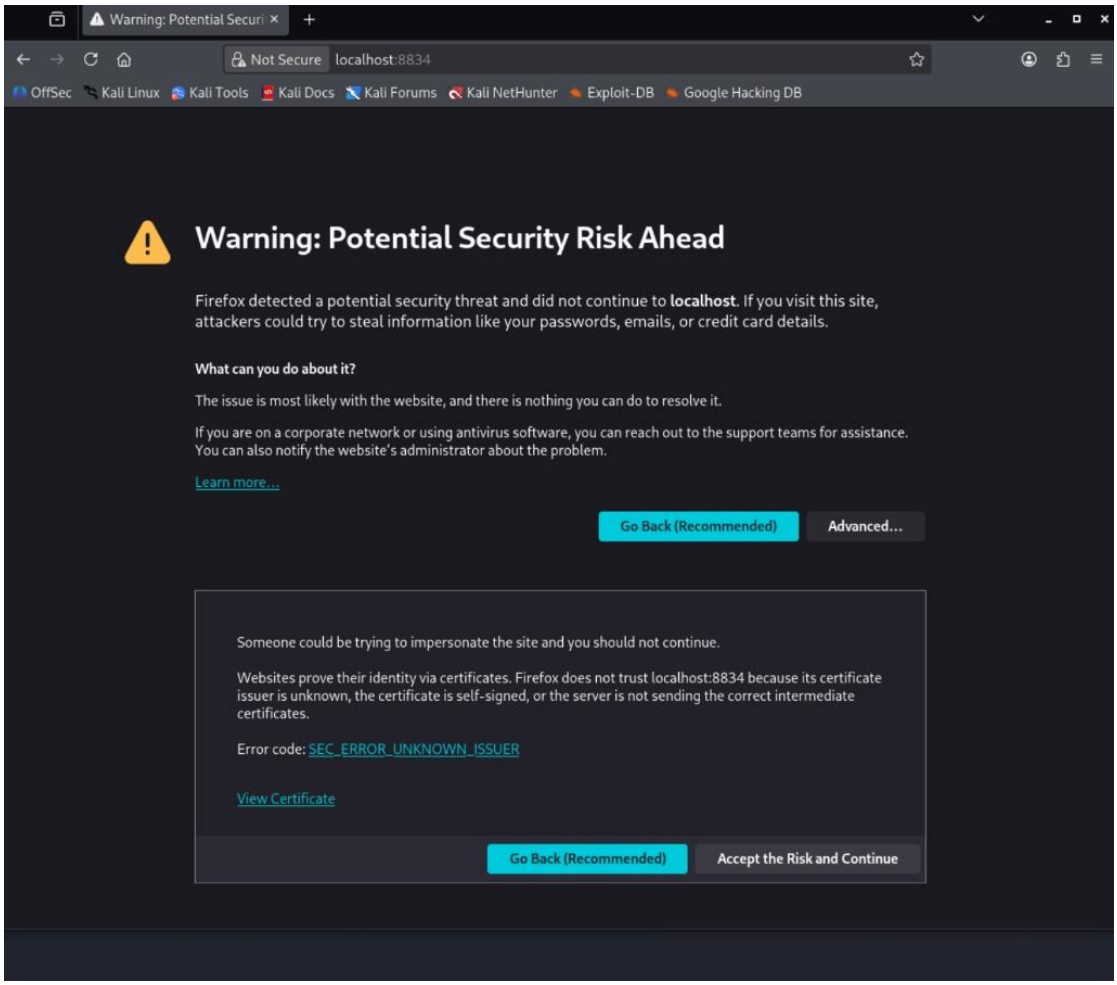


Figure 3. The Nessus web-based configuration wizard

Target Configuration

Two target virtual machines were identified for the scan:

1. WordPress Server: Located at IP 10.0.2.3
2. OWASP Juice Shop: Located at IP 10.0.2.5

Connectivity was verified via ICMP ping tests from the Kali attacker machine (10.0.2.15) to both targets, showing 0% packet loss.

```
┌──(kali㉿kali)-[~]
└─$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:63:b0:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 416sec preferred_lft 416sec
    inet6 fe80::e63c:89b6:7983:517b/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(kali㉿kali)-[~]
└─$ ping 10.0.2.5
PING 10.0.2.5 (10.0.2.5) 56(84) bytes of data.
64 bytes from 10.0.2.5: icmp_seq=1 ttl=64 time=1.21 ms
64 bytes from 10.0.2.5: icmp_seq=2 ttl=64 time=1.04 ms
64 bytes from 10.0.2.5: icmp_seq=3 ttl=64 time=1.51 ms
64 bytes from 10.0.2.5: icmp_seq=4 ttl=64 time=1.46 ms
64 bytes from 10.0.2.5: icmp_seq=5 ttl=64 time=1.44 ms
^C
--- 10.0.2.5 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4016ms
rtt min/avg/max/mdev = 1.044/1.330/1.505/0.176 ms

┌──(kali㉿kali)-[~]
└─$ ping 10.0.2.3
PING 10.0.2.3 (10.0.2.3) 56(84) bytes of data.
64 bytes from 10.0.2.3: icmp_seq=1 ttl=64 time=1.43 ms
64 bytes from 10.0.2.3: icmp_seq=2 ttl=64 time=1.07 ms
64 bytes from 10.0.2.3: icmp_seq=3 ttl=64 time=0.947 ms
64 bytes from 10.0.2.3: icmp_seq=4 ttl=64 time=2.07 ms
64 bytes from 10.0.2.3: icmp_seq=5 ttl=64 time=1.63 ms
^C
--- 10.0.2.3 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4083ms
rtt min/avg/max/mdev = 0.947/1.428/2.071/0.403 ms
```

Figure 4. Verification of network connectivity between Kali Linux attacker machine (10.0.2.15), and the scan targets.

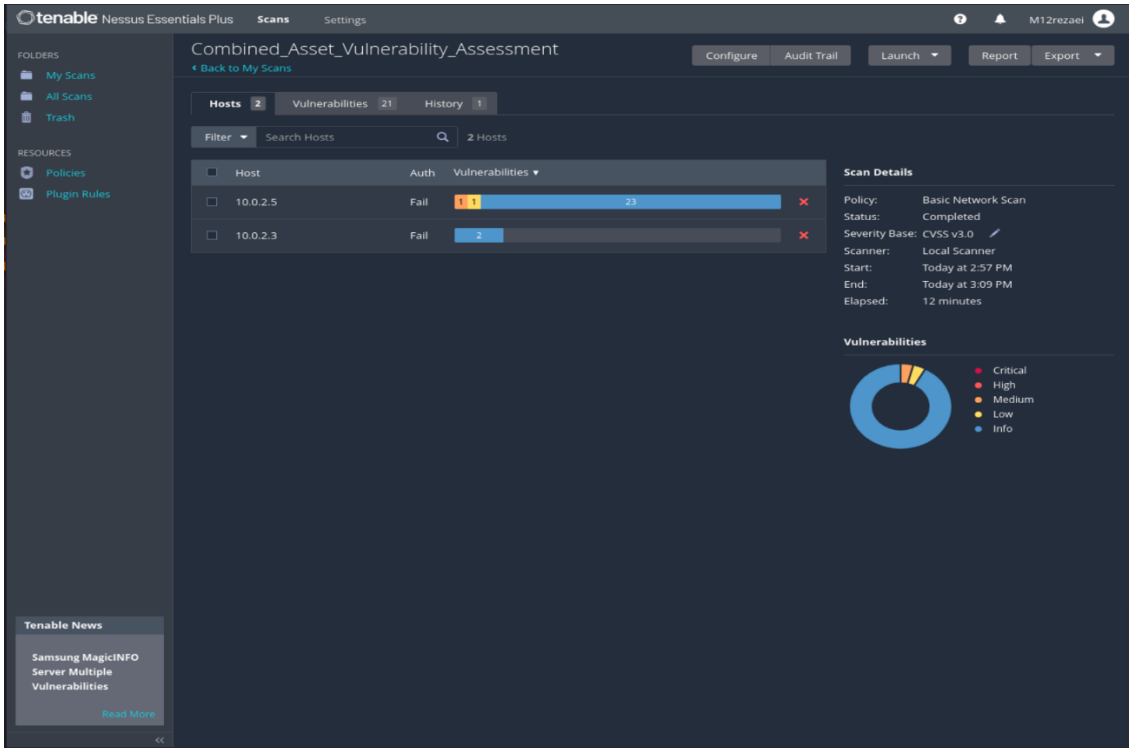
Scan Results Summary

The scan, titled "Combined_Asset_Vulnerability_Assessment," was executed on March 17, 2026, using a Basic Network Scan policy.

Table 1. Vulnerability Distribution by Asset

Target IP	Hostname	Total Vulnerabilities	Critical	High	Medium	Low	Info
10.0.2.3	WordPress	2	0	0	0	0	2
10.0.2.5	Juice Shop	25	0	0	1	1	23

Analysis: The initial automated scan identified a total of 27 findings across two assets. The OWASP Juice Shop (10.0.2.5) presents a higher risk profile, as the identified SSH vulnerability could allow attacker to perform downgrade attack, potentially compromising the confidentiality and integrity of encrypted communication. In contrast, the WordPress (10.0.2.3) server returned only informational results. This suggests that while the WordPress perimeter is currently hardened against network probes, the Juice Shop requires immediate configuration updates to mitigate potential MitM (Man-in-the-Middle) attacks.



Detailed Finding and Remediation

Target: 10.0.2.5 (OWASP Juice Shop)

Medium: SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)

Description: The remote SSH server is vulnerable to a Man-in-the-Middle (MitM) attack that can downgrade security by truncating the extension negotiation message.

Remediation: Disable affected algorithms (ChaCha20-Poly1305 or CBC with Encrypt-then-MAC) or update the SSH server to support strict key exchange countermeasures.

Low: ICMP Timestamp Request Remote Date Disclosure

Description: The host responds to ICMP timestamp requests, allowing an attacker to determine the system time, which can assist in defeating time-based authentication.

Remediation: Configure the firewall to filter out ICMP type 13 (request) and type 14 (reply) messages.

Target: 10.0.2.3 (WordPress)

The scan primarily returned informational data, including traceroute information and scan metadata. No high-risk vulnerabilities were identified in this specific uncredentialed scan.

Conclusion

The assessment successfully identified a significant SSH vulnerability on the Juice Shop asset. While the WordPress server appeared secure, the presence of the 'Terrapin' vulnerability on the Juice Shop highlights the need for ongoing configuration auditing. It is noted that these scans were uncredentialed; therefore, the 'Attack Surface' assessed was limited to network-facing

services. Future iterations will include credentialed scans to achieve a deeper ‘Defense in Depth’ assessment.

Reference

[1] H. Anderson, "Introduction to Nessus," *SecurityFocus Infocus*, Oct. 28, 2003. [Online]. Available: http://www.securityfocus.com/infocus/1741.

[2] L. Harrison, R. Spahn, M. Iannacone, E. Downing, and J. R. Goodall, "NV: Nessus vulnerability visualization for the web," in *Proc. 9th Int. Symp. Visualization for Cyber Security (VizSec '12)*, Seattle, WA, USA, Oct. 2012, pp. 25–33. [Online]. Available: https://doi.org/10.1145/2379690.2379694.